GD GOENKA UNIVERSITY
BACHELOR OF TECHNOLOGY · COMPUTER SCIENCE ENGINEERING

PHASE 1 → PHASE 2 HANDOFF SPECIFICATION

AI-Powered Recruitment & Applicant Tracking System

Seven resolved API gaps, finalised contracts, and the implementation-ready boundary between UX design and core platform development

RESOLVED GAPS · API CONTRACT · DATA MODEL · RBAC · AI BOUNDARY · DEFINITION OF DONE

SUBMITTED BY
Riya Jaiswal

ACADEMIC YEAR
2026–27

HANDOFF VERSION
1.0

DATE
August 8, 2026

GOVERNING DOCS
PRD v3.0 · Phase 1 v1.0

STATUS
B1+B2 approved · v1.1

How to read this document

Every statement carries a provenance label. Nothing is unlabelled.

LABEL	MEANING
[PRD]	Stated in Master PRD v3.0
[P1]	Design decision made in Phase 1 and already reviewed
[PROP]	Proposed implementation detail — not in either document, needs approval
[NOT SPECIFIED]	Absent from both documents; flagged rather than assumed

Decisions approved by the project owner (8 Aug 2026)

REF	DECISION	EFFECT ON THIS DOCUMENT
B1 / D2	**`job_assignments` table approved** — `id`, `job_id`, `user_id`, unique `(job_id, user_id)`. Enforces the Hiring Manager "assigned jobs only" restriction.	§D row 3 promoted from **[PROP]** to **[APPROVED]**. Requires PRD §17 amendment.
B2 / D1	**Pipeline stages: the 6 PRD §14.1 defaults are seeded; stages are configurable per job per FR5.1.** "Shortlisted" is **not** a mandatory global stage — it may be added per job.	§D row 5 confirmed. No schema change; `pipeline_stages` already models this.

Corrections applied in v1.1

REF	WAS	NOW
C1a	"30 screens" (Phase 1 Task 5)	**37 screens** — auth subtotal omitted SC-03
C1b	"21 screens built in Phase 2" (§E)	**28 of 37**
C1c	"13 tables for Phase 2" (§D prose)	**14 tables** — matched its own 14-row table and the DoD
C1d	"31/31 FR clauses" (audit)	**32/32** — FR1.1–FR8.4 totals 32

Scope boundary [PRD §29]: Phase 2 = "P2 — Core Platform Development": *job management, application intake, pipeline, RBAC, audit logging*. AI screening is **P3**. This document specifies contracts for AI-dependent features so Phase 3 has a fixed target, but marks them **Deferred** where they are not built in Phase 2.

PART 1 — RESOLVED GAPS

Seven gaps from Phase 1 Task 12, Table 12.3. All follow PRD §23.1 conventions: `/v1` prefix, Bearer JWT, cursor pagination (`?cursor=&limit=`), RFC 7807 `application/problem+json` errors.

Common error responses — apply to every endpoint below unless overridden:

STATUS	CONDITION
`400`	Malformed request body or query parameter
`401`	Missing, expired, or invalid access token
`403`	Authenticated but role not permitted (§24.2)
`404`	Resource absent **or outside the caller's tenant** — never 403, to avoid existence disclosure [PRD §26, BR-06]
`429`	Rate limit exceeded [PRD §23.1]
`500`	Unhandled server error

Gap 1 — Hiring Manager review queue

PRD connection. [PRD] FR5.3 (scorecards visible to hiring team) · §24.2 "View AI rankings + rationale ✓ **(assigned jobs only)**" · US-05. **[P1]** Screen HM-01. The *screen* is a Phase 1 decision; the *assigned-jobs scoping rule* it implements is PRD.

`GET /v1/me/reviews`

PROPERTY	VALUE
Role	Hiring Manager, Administrator
Query parameters	`status` (optional, `pending | completed` , default `pending`)· `cursor` (optional, opaque)· `limit` (optional, 1–100, default 25)
Request body	None

Response `200`

```
{
  "data": [
    {
      "applicationId": "uuid",
      "jobId": "uuid",
      "jobTitle": "string",
      "candidateName": "string",
      "requestedAt": "2026-08-08T10:00:00Z",
      "scorecardSubmitted": false
    }
  ],
  "nextCursor": "string | null"
}
```

Validation rules 1. `status` must be one of the two enum values — reject others with `400`. 2. `limit` must be an integer 1–100. 3. Results are scoped server-side to jobs where the caller appears in `job_assignments` — **the client cannot widen this scope by parameter** [PRD NFR6].

Error cases

STATUS	CONDITION
`400`	`status` not in enum; `limit` out of range; malformed cursor
`403`	Caller is Recruiter or Candidate
`200` + empty `data`	HM has no assignments — an empty queue is **not** an error

[PROP] `status` filter, `requestedAt`, `scorecardSubmitted` — display conveniences, not PRD-named.

Gap 2 — Recruiter-defined ranking weights

PRD connection. [PRD] FR4.2 “Recruiters can adjust ranking weights per job” · §21.3 “Re-scores the pool against the new weighting; **appends** new `match_scores` rows” · §19.3 Table 19.1 feature set · BR-07 (allow-list).

Phase status: DEFERRED to Phase 3. Contract fixed now; no scoring engine exists in Phase 2.

`GET /v1/jobs/:id/ranking-weights`

PROPERTY	VALUE
Role	Recruiter, Administrator
Response `200`	`{ "weights": { … }, "isDefault": true, "updatedAt": "…" }`

`PUT /v1/jobs/:id/ranking-weights`

PROPERTY	VALUE
Role	Recruiter, Administrator
Request body	See below

```
{
  "weights": {
    "semantic_similarity":   0.30,
    "skill_overlap":         0.30,
    "years_experience_delta":0.15,
    "education_match":       0.10,
    "recency_relevant_exp":  0.10,
    "certification_match":   0.05
  }
}
```

Response `200`

```
{
  "weights": { "…": 0.0 },
  "affectedApplicationCount": 147,
  "rescoreStatus": "queued"
}
```

Validation rules 1. **Key allow-list [BR-07]:** keys must be **exactly** the six features in PRD Table 19.1 — no more, no fewer. Any unknown key is rejected. This is the enforcement point for "no protected attribute may be used as a model input." 2. Each value is a number in `[0, 1]`. 3. Values must sum to `1.0 ± 0.001`. **[PROP]** — normalisation is a Phase 1 design decision (§9.9), not a PRD statement. 4. Job must exist within the caller's tenant.

Error cases

STATUS	CONDITION
`400`	Unknown key; missing key; value outside `[0,1]`; sum ≠ 1.0
`403`	Caller is Hiring Manager or Candidate
`404`	Job absent or outside tenant
`409`	Job status is `closed` — weights cannot be changed on a closed requisition **[PROP]**

[NOT SPECIFIED] Behaviour when `ai_scoring_enabled = false`. The PRD does not say whether weights may be set on a job with AI disabled. **Recommendation:** accept the write and return `rescoreStatus: "not_applicable"`, since disabling is reversible and the setting should survive. Requires your decision.

Gap 3 — Resume parse review queue

PRD connection. [PRD] FR3.2 "A per-field parsing confidence score is generated; fields below the configured threshold are **flagged for review rather than silently accepted**" · §20 stage 5 (threshold 0.75). **[P1]** Screen RC-14 aggregates flagged fields into a queue.

> **Phase status: DEFERRED to Phase 3.** No parser exists in Phase 2. The `parsed_profiles` table **is** created in Phase 2 so the candidate manual-entry path (FR2.5) has storage.

`GET /v1/jobs/:id/parse-review`

PROPERTY	VALUE
Role	Recruiter, Administrator
Query parameters	`cursor`, `limit` (1–100, default 25)

Response `200`

```
{
  "data": [
    {
      "applicationId": "uuid",
      "parsedProfileId": "uuid",
      "candidateName": "string",
      "flaggedFields": [
        { "field": "work_history[0].employer", "extractedValue": "string", "confidence": 0.62 }
      ]
    }
  ],
  "nextCursor": "string | null"
}
```

`PATCH /v1/parsed-profiles/:id`

PROPERTY	VALUE
Role	Recruiter, Administrator (recruiter-side confirmation) · Candidate (owner, pre-submission correction per FR2.2)
Request body	`{ "fields": { "<fieldPath>": { "value": <any>, "confirmed": true } } }`

Validation rules 1. `fieldPath` must resolve to a known field in the `parsed_profiles` schema — arbitrary keys rejected. 2. `value` type must match the field's declared type. 3. Candidate callers may only patch a profile attached to their own application, and only **before** submission [BR-06, FR2.2]. 4. Confirming a field sets its confidence to `1.0` and records the confirming actor. **[PROP]**

Error cases

STATUS	CONDITION
`400`	Unknown field path; type mismatch
`403`	Recruiter from another tenant; Hiring Manager (no correction rights per §24.2)
`404`	Profile absent or outside tenant / not owned by the candidate
`409`	Application already submitted and caller is the Candidate

Gap 4 — Audit log query / filter

PRD connection. [PRD] FR8.3 · NFR8 · NFR11 (correlation ID) · **§9.3 steps 2–4** — the Administrator journey requires filtering by *job, date range, action type*, then reconciling against model versions. §23.2 lists only `/audit-logs/export`, so the query the journey depends on has no endpoint. **[P1]** Screen AD-04.

`GET /v1/audit-logs`

PROPERTY	VALUE
Role	**Administrator only** [PRD §24.2]
Query parameters	`jobId` (uuid, optional) · `from` (ISO 8601 date-time, optional) · `to` (optional) · `actionType` (optional) · `cursor` · `limit` (1–100, default 25)

Response `200`

```
{
  "data": [
    {
      "id": "uuid",
      "createdAt": "2026-08-08T10:00:00Z",
      "actorId": "uuid",
      "actorEmail": "string",
      "action": "application.stage_changed",
      "resourceType": "application",
      "resourceId": "uuid"
    }
  ],
  "nextCursor": "string | null",
  "totalCount": 1284
}
```

`GET /v1/audit-logs/:id`

Response `200` adds: `beforeState`, `afterState`, `correlationId`, `modelVersion` (present only where the entry references a `match_score`), `overrideReason`.

Validation rules 1. If both `from` and `to` are supplied, `from` ≤ `to`. 2. `actionType` must be a known action string; unknown values return `400` rather than silently matching nothing. 3. **No write verbs exist on this resource.** `audit_logs` holds no UPDATE or DELETE grant [PRD §17.3], so `PATCH` / `DELETE` must return `405 Method Not Allowed`.

Error cases

STATUS	CONDITION
`400`	`from` > `to`; unrecognised `actionType`; malformed date
`403`	Any non-Administrator role
`404`	Entry absent or outside tenant
`405`	Any attempt to mutate an audit entry

[NOT SPECIFIED] Maximum permitted date-range span. The PRD sets no bound. **Recommendation:** cap at 366 days per query to protect NFR1 page-load targets. Requires your decision. **[PROP]** `totalCount`, `actorEmail` denormalisation.

Gap 5 — User and role management

PRD connection. [PRD] FR8.1 “RBAC enforced for Administrator, Recruiter, Hiring Manager, Candidate” · §24.2 “Manage users and roles — Admin ✓”. **[P1]** Screen AD-02.

`GET /v1/admin/users`

PROPERTY	VALUE
Role	Administrator only
Query parameters	`role` (optional filter) · `cursor` · `limit`
Response `200`	`{ data: [{ id, email, role, createdAt, lastActiveAt }], nextCursor }`

`POST /v1/admin/users`

PROPERTY	VALUE
Role	Administrator only
Request body	`{ "email": "string", "role": "ADMIN | RECRUITER | HIRING_MANAGER" }`
Response `201`	Created user record

`PATCH /v1/admin/users/:id/role`

PROPERTY	VALUE
Role	Administrator only
Request body	`{ "role": "ADMIN | RECRUITER | HIRING_MANAGER" }`

Validation rules 1. `email` must be a valid address and unique within the tenant. 2. `CANDIDATE` **is not assignable here.** Candidate identity is created by application submission and lives in the `candidates` table, which PRD §17.2 keeps separate from `users` . 3. **Last-administrator guard:** the final remaining `ADMIN` in a tenant cannot be demoted or removed. **[PROP]** — not PRD-stated, but without it a tenant can lock itself out of FR8.2 and FR8.3 permanently. 4. Target user must be in the caller’s tenant.

Error cases

STATUS	CONDITION
`400`	Invalid email; role not in enum
`403`	Non-Administrator caller
`404`	Target user outside tenant
`409`	Email already exists in tenant
`422`	Last-administrator demotion attempt

[NOT SPECIFIED] The invitation delivery mechanism — whether `POST /v1/admin/users` sends an email invite or creates a pending account for out-of-band credential delivery. **Recommendation:** create the record with status `invited`; email delivery reuses `NotificationsModule` (FR2.3 infrastructure). Requires your decision.

Gap 6 — Session revocation

PRD connection. [PRD] FR8.4 "Administrators can revoke all active sessions for a user immediately" · §24.1 "All refresh tokens for a user are revocable immediately from the admin panel". **[P1]** Screen AD-06.

`DELETE /v1/admin/users/:id/sessions`

PROPERTY	VALUE
Role	Administrator only
Request body	None
Response `200`	`{ "revokedCount": 3, "revokedAt": "2026-08-08T10:00:00Z" }`

Validation rules 1. Target user must be in the caller's tenant. 2. **Self-revocation guard:** an Administrator cannot revoke their own sessions through this endpoint — that is what `POST /v1/auth/logout` is for. Prevents accidental self-lockout mid-task. **[PROP]** 3. Revocation invalidates **all** refresh tokens for the user. Access tokens already issued remain valid until their 15-minute expiry [PRD §24.1] — this is a property of stateless JWT, not a defect, and the UI must state it.

Error cases

STATUS	CONDITION
`403`	Non-Administrator caller
`404`	Target user outside tenant
`422`	Caller attempted self-revocation

[NOT SPECIFIED] Whether access-token revocation must also be immediate. PRD §24.1 says *refresh* tokens are revocable; it is silent on the ≤15-minute access-token window. **Recommendation:** accept the window and document it; a deny-list would add Redis lookup to every request and work against NFR1. Requires your decision.

Gap 7 — Candidate interview slot selection

PRD connection. [PRD] FR6.2 "Candidates receive a self-service scheduling link" · FR6.3 (graceful degradation) · §9.2 step 6. **[P1]** Screen CA-06.

> **Phase status: DEFERRED pending Decision D3** (whether FR6 is in Phase 2 or Phase 2b).

`GET /v1/scheduling/:token`

PROPERTY	VALUE
Auth	The scheduling token itself — no session required
Response `200`	`{ jobTitle, interviewerNames: [], slots: [{ slotId, startsAt, endsAt, timezone }], expiresAt }`

`POST /v1/scheduling/:token/confirm`

PROPERTY	VALUE
Auth	Scheduling token
Request body	`{ "slotId": "uuid" }`
Response `200`	`{ interviewId, scheduledAt, calendarEventId }`

Validation rules 1. Token signature valid and not expired. 2. `slotId` must belong to the set offered by *this* token — a candidate cannot book an arbitrary slot. 3. Slot must still be unclaimed at commit time (transactional check, not read-then-write). 4. The token grants access to **one** interview only; it confers no other read access [BR-06].

Error cases

STATUS	CONDITION
`400`	Malformed `slotId`
`401`	Token invalid or expired
`404`	Token unknown
`409`	Slot claimed concurrently by another action
`410`	Interview cancelled or already scheduled
`503`	Calendar provider unavailable → client falls back to manual scheduling [FR6.3]

[PROP] — requires explicit approval. Token-based authentication is a **proposed mechanism**. PRD FR6.2 requires a "self-service scheduling link" but specifies no auth model, and §24.2 grants the Candidate role no session-based access to interview resources. Proposed: a signed, single-purpose, expiring token embedded in the link. This is an authentication design decision and should not be made unilaterally.

PART 2 — PHASE 2 HANDOFF

A. Finalised functional requirements

Table A.1 — FR scope for Phase 2 *(all from PRD §11; none added, none removed)*

FR	REQUIREMENT	PHASE 2	NOTE
FR1.1	Create, edit, publish, close job postings	✅ Full	
FR1.2	Structured job fields	✅ Full	
FR1.3	Duplicate posting as template	✅ Full	
FR1.4	Per-job `ai_scoring_enabled`, Administrator-only	✅ Full	Flag is honoured by UI even before AI exists
FR2.1	Apply via resume upload with auto-fill	⚠️ Partial	Upload + storage in P2; auto-fill in P3
FR2.2	Review and correct auto-filled fields	✅ Full	Manual-entry variant is the P2 path
FR2.3	Confirmation and status-change email	✅ Full	
FR2.4	Application flow meets WCAG 2.1 AA	✅ Full	Audited in P4
FR2.5	Submission succeeds regardless of parsing	✅ Full	**Testable in P2 precisely because parsing is absent**
FR3.1–3.4	Resume parsing, OCR, confidence	❌ P3	`parsed_profiles` table created in P2
FR4.1	Match score with rationale	❌ P3	Schema + UI empty state in P2
FR4.2	Per-job ranking weights	❌ P3	Contract fixed (Gap 2)
FR4.3	Override score with reason	⚠️ Partial	Endpoint + audit + BR-03 validation in P2; live data in P3
FR4.4	Persist model version + feature vector	⚠️ Schema only	Columns exist and are `NOT NULL`
FR4.5	AI-disabled → reverse-chronological, no score	✅ Full	**Default P2 behaviour**
FR5.1	Kanban with configurable stages	✅ Full	See Decision D1
FR5.2	Bulk actions	✅ Full	
FR5.3	Comments and scorecards visible to team	✅ Full	
FR5.4	Stage transitions recorded with actor + timestamp	✅ Full	
FR6.1–6.3	Interview scheduling	⏸️ Pending D3	

FR	REQUIREMENT	PHASE 2	NOTE
FR7.1–7.3	Analytics	⏸️ Pending D3	
FR8.1	RBAC across four roles	✅ Full	
FR8.2	Administrator per-job AI toggle	✅ Full	
FR8.3	Exportable audit log	✅ Full	
FR8.4	Immediate session revocation	✅ Full	

Business rules — all seven enforced in Phase 2 [PRD §13]. BR-02 and BR-07 are enforced structurally (schema constraint and key allow-list) even though no AI runs yet.

B. Finalised API contract

27 endpoints built in Phase 2. ✅ = in PRD §23.2 · ⚠️ = gap requiring the Decision D4 amendment.

Table B.1 — Phase 2 endpoints

#	METHOD	ENDPOINT	ROLE	MODULE
1	POST	`/v1/auth/login` ✅	Public	Auth
2	POST	`/v1/auth/refresh` ✅	Refresh cookie	Auth
3	POST	`/v1/auth/logout` ✅	Authenticated	Auth
4	GET	`/v1/auth/me` ⚠️	Authenticated	Auth
5	POST	`/v1/jobs` ✅	Recruiter, Admin	Jobs
6	GET	`/v1/jobs` ✅	Recruiter, HM, Admin	Jobs
7	GET	`/v1/jobs/:id` ⚠️	Recruiter, HM, Admin	Jobs
8	PATCH	`/v1/jobs/:id` ✅	Recruiter, Admin	Jobs
9	POST	`/v1/jobs/:id/duplicate` ✅	Recruiter, Admin	Jobs
10	GET	`/v1/public/jobs` ⚠️	Public	Jobs
11	GET	`/v1/public/jobs/:id` ⚠️	Public	Jobs
12	POST	`/v1/applications` ✅	Public	Applications
13	GET	`/v1/applications/:id` ✅	Candidate (owner), Recruiter, Admin	Applications
14	GET	`/v1/jobs/:id/candidates` ✅	Recruiter, HM, Admin	Applications
15	PATCH	`/v1/applications/:id/stage` ✅	Recruiter, Admin	Pipeline
16	PATCH	`/v1/applications/bulk/stage` ⚠️	Recruiter, Admin	Pipeline
17	PATCH	`/v1/applications/:id/score` ✅	Recruiter, Admin	Applications
18	POST	`/v1/applications/:id/scorecards` ✅	Recruiter, HM, Admin	Scorecards
19	GET	`/v1/me/reviews` ⚠️ **Gap 1**	HM, Admin	Scorecards
20	GET	`/v1/admin/users` ⚠️ **Gap 5**	Admin	Admin
21	POST	`/v1/admin/users` ⚠️ **Gap 5**	Admin	Admin
22	PATCH	`/v1/admin/users/:id/role` ⚠️ **Gap 5**	Admin	Admin
23	DELETE	`/v1/admin/users/:id/sessions` ⚠️ **Gap 6**	Admin	Admin
24	PATCH	`/v1/admin/jobs/:id/ai-scoring` ✅	Admin	Admin

#	METHOD	ENDPOINT	ROLE	MODULE
25	GET	`/v1/audit-logs` ⚠️ **Gap 4**	Admin	Audit
26	GET	`/v1/audit-logs/:id` ⚠️ **Gap 4**	Admin	Audit
27	GET	`/v1/audit-logs/export` ✅	Admin	Audit

Table B.2 — Specified but deferred

METHOD	ENDPOINT	GAP	DEFERRED TO
GET / PUT	`/v1/jobs/:id/ranking-weights`	2	Phase 3
GET	`/v1/jobs/:id/parse-review`	3	Phase 3
PATCH	`/v1/parsed-profiles/:id`	3	Phase 3 (candidate path may land in P2 — see D5)
GET / POST	`/v1/scheduling/:token`	7	Pending D3
POST	`/v1/interviews`	—	Pending D3
GET	`/v1/analytics/funnel`	—	Pending D3
POST	`/internal/ai/{parse,rank,explain}`	—	Phase 3

C. Finalised roles and permissions

Reproduced verbatim from **[PRD §24.2 Table 24.1]**. Not modified.

ACTION	RECRUITER	HIRING MANAGER	CANDIDATE	ADMINISTRATOR
Create / edit jobs	✓	—	—	✓
View AI rankings + rationale	✓	✓ *(assigned jobs)*	—	✓
Override AI score	✓	—	—	✓
Move pipeline stage	✓	—	—	✓
Submit scorecard	✓	✓	—	✓
View own application status	—	—	✓	—
Enable / disable AI scoring	—	—	—	✓
Export audit log	—	—	—	✓
Manage users and roles	—	—	—	✓

Enforcement layers [PRD §15.3, NFR6] — all three applied globally, not per-controller:

GUARD	RESPONSIBILITY
`RolesGuard`	Route-level role check from `@Roles()` metadata
`TenantGuard`	Scopes every query to `req.user.companyId` — mitigates risk R-09
`CandidateOwnershipGuard`	Restricts candidate reads to owned rows; returns **404, not 403** [BR-06]

D. Finalised database entities

14 tables for Phase 2 — PRD §17.2 Table 17.1 (14) minus `interviews` (pending D3), plus `job_assignments` (**approved B1**).

#	TABLE	PK	FOREIGN KEYS	CRITICAL CONSTRAINTS
1	`companies`	`id`	—	—
2	`users`	`id`	`company_id`	`email` unique per tenant; `role` enum ×4
3	`job_assignments` **[APPROVED B1]**	`id`	`job_id`, `user_id`	unique `(job_id, user_id)`; both FKs `ON DELETE CASCADE`
4	`jobs`	`id`	`company_id`, `created_by`	GIN on `required_skills`; `ai_scoring_enabled` default `false`
5	`pipeline_stages`	`id`	`job_id`	unique `(job_id, position)`; **seeded with the 6 PRD §14.1 defaults, configurable per job (approved B2)**
6	`candidates`	`id`	—	`deleted_at` soft delete [BR-05]
7	`applications`	`id`	`job_id`, `candidate_id`, `resume_id`	composite idx `(job_id, current_stage)`
8	`resumes`	`id`	`application_id`	partial idx where `parse_status <> 'completed'`
9	`parsed_profiles`	`id`	`resume_id`	jsonb `skills`, `work_history`, `education`
10	`ai_model_versions`	`id`	—	seeded `placeholder-v0`, status `inactive`
11	`match_scores`	`id`	`application_id`, `model_version_id`, `overridden_by`	**`rationale` NOT NULL [BR-02]** · `feature_vector` NOT NULL [FR4.4] · CHECK `composite_score` ∈ [0,1] · GIN on `rationale`
12	`stage_history`	`id`	`application_id`, `changed_by`	append-only [FR5.4]
13	`scorecards`	`id`	`application_id`, `author_id`	—
14	`audit_logs`	`id`	`actor_id`	**`REVOKE UPDATE, DELETE`** [§17.3] · `correlation_id` NOT

#	TABLE	PK	FOREIGN KEYS	CRITICAL CONSTRAINTS
				NULL · idx `(resource_id, created_at DESC)`

Conventions [PRD §17.1]: `snake_case`; UUID primary keys; `created_at` + `updated_at` on every table; `deleted_at` on candidate-facing entities.

Two entries need your attention: - **`ai_model_versions`** is created in Phase 2 despite no AI, because `match_scores.model_version_id` is `NOT NULL REFERENCES ai_model_versions(id)` [§17.3]. The FK target must exist for the schema to be valid. - **`job_assignments`** is **[APPROVED B1]**. §24.2 requires Hiring Managers to see "assigned jobs only" but PRD §17 defines no join table. Approved 8 Aug 2026; a PRD §17 amendment is still required to keep the PRD accurate. - **`pipeline_stages`** is seeded per job with the six PRD §14.1 defaults — Applied, Screening, Interview, Offer, Hired, Rejected — and remains editable per job to satisfy FR5.1 (approved B2). "Shortlisted" is available as a per-job configuration, not a global stage.

Session storage: refresh tokens in **Redis** rather than a table **[PROP]** — §16 already provisions Redis for session cache, and FR8.4 revocation is a key-deletion operation.

E. Finalised frontend screens

From Phase 1 Task 5. **28 screens built in Phase 2** of the **37** inventoried (counts corrected in v1.1).

SCREEN	ROLE	PHASE 2	NOTE
SC-01 Login · SC-02 MFA	All	✅	
RC-01 Dashboard	Recruiter	✅	
RC-02 Job list · RC-03 Create/edit · RC-04 Detail	Recruiter	✅	
RC-05 Candidate list	Recruiter, HM	✅	**AI-disabled variant (FR4.5) is the P2 rendering**
RC-06 Candidate detail	Recruiter, HM	✅	Rationale panel renders empty state
RC-07 Override modal	Recruiter	⚠️ Built, inert	BR-03 validation testable against seeded data
RC-08 Ranking weights	Recruiter	❌ P3	
RC-09 Kanban · RC-10 Bulk	Recruiter	✅	
RC-11 Scheduling	Recruiter	⏸️ D3	
RC-12 Analytics	Recruiter	⏸️ D3	
RC-13 Scorecard	Recruiter, HM	✅	
RC-14 Parse review	Recruiter	❌ P3	
HM-01…HM-04	HM	✅	Rationale read-only, empty in P2
HM-05 Compare	HM	❌ Deferred	US-12 “Could”
CA-01 Job listing	Candidate	✅	
CA-02 Application form	Candidate	✅	
CA-03 Parsed review	Candidate	✅ **manual-entry variant**	Auto-fill in P3
CA-04 Confirmation · CA-05 Status	Candidate	✅	
CA-06 Slot selection	Candidate	⏸️ D3	
AD-01…AD-06	Admin	✅	
SY-01 Errors	All	✅	
SY-02 AI unavailable	Recruiter	❌ P3	No AI to be unavailable

Design tokens, component specs, and states come from **Phase 1 Tasks 7–8**. No new design work in Phase 2.

F. Finalised backend modules

[PRD §15.3] names all ten. Cross-cutting components are built **before** any feature module.

ORDER	MODULE	FRS	PHASE 2 SCOPE
0	`common/` guards, interceptors, filters	NFR6, NFR11, BR-03, BR-06	Full — prerequisite for everything
1	`AuthModule`	FR8.1, FR8.4, §24.1	Full
2	`AuditModule`	FR8.3, BR-03, NFR8	Full
3	`JobsModule`	FR1.1–FR1.4	Full
4	`ApplicationsModule`	FR2.1–FR2.5	Full
5	`CandidatesModule`	BR-05, BR-06	Full
6	`PipelineModule`	FR5.1–FR5.4	Full
7	`ScorecardsModule`	FR5.3	Full
8	`AdminModule`	FR8.1, FR8.2	Full
9	`NotificationsModule`	FR2.3	Full — console transport in P2 **[PROP]**
10	`AiModule`	§19.1 boundary	**Interface + null provider only**
—	`InterviewsModule`	FR6.1–6.3	⏸ D3
—	`AnalyticsModule`	FR7.1–7.3	⏸ D3

`ScorecardsModule` is split out from `PipelineModule` **[PROP]** for clarity; PRD §15.3 places scorecards under PipelineModule. Merge on request.

G. AI service integration boundary

The contract Phase 3 must satisfy — fixed now, implemented later.

Phase 2 defines a single seam in `AiModule`:

```
interface AiScoringPort            // [PROP] naming; boundary itself is [PRD §15.1 principle 1]
  requestParse(resumeId)      → void        // fire-and-forget, queued
  getScore(applicationId)     → MatchScore | NotScored
```

Phase 2 supplies `NullAiProvider`: `requestParse` is a no-op; `getScore` always returns `NotScored`. Every consumer therefore exercises the not-scored path from day one, which is exactly the FR4.5 / BR-02 rendering the UI must get right.

Boundary rules — binding on Phase 3:

RULE	SOURCE
The core API **never** imports model code. Communication is HTTP to the AI service plus SQS events.	[PRD §15.1 principle 1]
A degraded or absent AI service must not degrade the recruiter workflow.	[PRD §15.1]
`match_scores` writes are **atomic**: score + rationale + feature vector + model version in one transaction.	[PRD §21.2 step 8, FR4.4]
If rationale generation fails, **the transaction aborts** — no partial row.	[PRD BR-02]
Feature keys are restricted to the PRD Table 19.1 allow-list.	[PRD BR-07]
AI output is advisory only. **No AI-originated path may transition an application's stage.**	[PRD BR-01]

What Phase 2 does not build: parsing, embeddings, ranking, SHAP, MLflow, fairness auditing, model training.

H. Authentication and authorisation

[PRD §24.1] — implemented exactly.

CONTROL	SPECIFICATION
Password hashing	Argon2id, minimum 12 characters, breach-list check at signup
Access token	JWT, 15-minute expiry
Refresh token	7 days, **rotating**; `httpOnly` + `Secure` + `SameSite=Strict`; previous token invalidated on use
SSO	OAuth2/OIDC — Google, Microsoft Entra ID
MFA	TOTP **required for Administrator**; optional for Recruiter and Hiring Manager
Revocation	All refresh tokens revocable immediately (FR8.4, Gap 6)
Authorisation	Enforced at the **API layer**, not the UI (NFR6)

[NOT SPECIFIED] Password reset / forgot-password (Phase 1 NS-03). Not in PRD §11. Not built in Phase 2. Operationally this leaves password auth without a recovery path — flagged as Decision D6.

I. Audit logging requirements

[PRD BR-03, FR8.3, NFR8, NFR11]

Mechanism: a global `AuditInterceptor` writes the record **before the originating request returns success** — logging is synchronous and non-optional [PRD §15.1 principle 4].

Every record contains: `actor_id` · `created_at` · `action` · `resource_type` · `resource_id` · `before_state` · `after_state` · `correlation_id`.

Table I.1 — Audited events in Phase 2

EVENT	ACTION STRING	FR / BR
Login success / failure	`auth.login_succeeded` / `auth.login_failed`	§24.1 **[PROP]** — not PRD-named
Session revocation	`auth.sessions_revoked`	FR8.4
Job created / updated / published / closed	`job.*`	FR1.1
Job duplicated	`job.duplicated`	FR1.3
Application submitted	`application.submitted`	FR2.1
Stage change (incl. bulk, per candidate)	`application.stage_changed`	**FR5.4**
Terminal decision	`application.hired` / `application.rejected`	**BR-01**
Score override	`score.overridden` — includes `override_reason`	**BR-03**
AI score generated	`score.generated`	FR4.4 — **hook wired, never fires in P2**
AI scoring toggled	`admin.ai_scoring_changed`	FR8.2, BR-04
Role changed / user invited	`admin.role_changed` / `admin.user_invited`	FR8.1
Audit export	`audit.exported`	FR8.3 **[PROP]**
Candidate erasure	`candidate.erased`	BR-05

Immutability: the application database role holds `INSERT` and `SELECT` only. No API path can update or delete an audit record [PRD §17.3].

J. Definition of Done for Phase 2

Functional - [ ] FR1.1–FR1.4 complete and audited - [ ] FR2.1–FR2.5 complete; **FR2.5 verified — submission returns 201 with no parser present** - [ ] FR4.5 verified — no score or rationale rendered anywhere in Phase 2 - [ ] FR5.1–FR5.4 complete; stage transitions written to `stage_history` with actor and timestamp - [ ] FR8.1–FR8.4 complete - [ ] All 27 endpoints in Table B.1 implemented and documented

Business rules — each with a passing failing-path test [PRD §26] - [ ] BR-01 — no API path transitions to Rejected/Hired from a system actor - [ ] BR-02 — inserting a `match_score` without rationale **fails at the database** - [ ] BR-03 — override without a reason rejected; audit written before response - [ ] BR-04 — Recruiter token on the AI toggle → **403** - [ ] BR-05 — soft-delete erasure preserves audit referential integrity - [ ] BR-06 — foreign candidate application → **404, not 403** - [ ] BR-07 — weight allow-list rejects any key outside Table 19.1

Non-functional - [ ] NFR4 — WCAG 2.1 AA on all Phase 2 flows (axe-core in CI + manual screen-reader pass) - [ ] NFR6 — RBAC verified by direct API calls that bypass the UI entirely - [ ] NFR10 — ≥80% unit coverage on business-logic modules - [ ] NFR11 — correlation ID traceable end-to-end

Data - [ ] 14 tables migrated with all §17 constraints and indexes - [ ] `audit_logs` UPDATE/DELETE grants revoked and **verified by a failing test** - [ ] `match_scores` NOT NULL and CHECK constraints verified

Quality - [ ] Unit, integration, and E2E suites **actually run green** — output shown, not asserted - [ ] Security scan: zero unresolved high/critical - [ ] API documentation complete per Step 11

Milestone - [ ] **M3 satisfied** — "Job management, application intake, and pipeline management functional end-to-end" [PRD §29 Table 29.2] - [ ] `AiScoringPort` seam present with null provider; Phase 3 can begin

Explicitly excluded from Phase 2 DoD: FR3.1–3.4, FR4.1–4.2, FR4.4 runtime, §19–§22 AI work, §26.7 AI regression, §26.8 fairness. All are **P3** [PRD §29].

PART 3 — PHASE 2 IMPLEMENTATION ORDER

Dependency-ordered. Each milestone ends in something runnable.

#	MILESTONE	DEPENDS ON	DELIVERS
M2.1	Monorepo scaffold, local infra, CI skeleton	—	`pnpm build` green; Postgres + Redis up
M2.2	Prisma schema, migrations, seed	M2.1	14 tables with constraints; audit grants revoked
M2.3	Cross-cutting guards, interceptors, RFC 7807 filter	M2.2	Audit-before-response; global tenant scoping
M2.4	AuthModule — JWT, rotation, Argon2id, MFA, revocation	M2.3	Login → protected route → refresh → logout
M2.5	RBAC — four roles, permission matrix, negative tests	M2.4	Every role 403/404s on every forbidden route
M2.6	JobsModule + RC-02/03/04	M2.5	Create → edit → publish → duplicate → close
M2.7	ApplicationsModule + CA-01…CA-05	M2.6	Apply with upload; **201 before any parsing**
M2.8	PipelineModule + Scorecards + RC-09/10, HM-01…04	M2.7	Kanban with keyboard equivalent; terminal-stage confirm
M2.9	AiModule seam + null provider	M2.7	`NotScored` rendering everywhere
M2.10	AdminModule + audit browser/export + API docs + tests	M2.4, M2.8	Export reconciles; suites green

Three orderings differ from a naive sequence, each for a reason: 1. **Guards before auth (M2.3 → M2.4)** — `TenantGuard` is global and `AuditInterceptor` must wrap auth's own writes. 2. **Audit early (M2.3)** —

BR-03 is a precondition for every auditable action; building it last would require retrofitting every prior module. 3. **AI seam before Admin (M2.9 → M2.10)** — the AI toggle in AdminModule needs something to toggle.

PART 4 — REMAINING DECISIONS REQUIRED FROM YOU

Table 4.1 — Blocking decisions

#	DECISION	RECOMMENDATION	BLOCKS	PRD AMENDMENT?
~~D1~~	~~Pipeline stages~~	✅ **RESOLVED 8 Aug 2026** — 6 PRD defaults seeded, per-job configurable; "Shortlisted" not global	—	No
~~D2~~	~~`job_assignments` table~~	✅ **RESOLVED 8 Aug 2026** — approved as specified	—	Yes — §17 amendment still outstanding
D3	**FR6 (interviews) + FR7 (analytics) in Phase 2?** Absent from your Step list; both Must-priority in §11.	**Defer to Phase 2b.** Both are additive with no upstream dependencies. Phase 2 DoD then states explicitly that it is partial against PRD P2.	Scope, DoD, Gap 7	No
D4	**Amend PRD §23.2 with the 10 unlisted endpoints** (7 Phase-1 gaps + `GET /v1/jobs/:id`, `GET /v1/public/jobs`, `GET /v1/auth/me`).	Authorise now; record as one amendment at Phase 2 close.	M2.4, M2.6, M2.7, M2.10	Yes
D5	**Scheduling-link authentication** (Gap 7 **[PROP]**). FR6.2 requires the link; §24.2 grants candidates no session access to interviews.	Signed, single-purpose, expiring token.	Gap 7 build — moot if D3 = defer	Yes — add to §24.1

Table 4.2 — Non-blocking, resolve before the named milestone

#	DECISION	RECOMMENDATION	NEEDED BY
D6	Password reset absent from PRD (NS-03) — leaves password auth with no recovery path	Add to PRD §31 backlog; **do not build silently**	Before Phase 2 close
D7	Access tokens remain valid ≤15 min after revocation (Gap 6)	Accept and document; a deny-list would work against NFR1	M2.4
D8	Audit query maximum date span (Gap 4)	Cap at 366 days	M2.10
D9	Ranking weights when `ai_scoring_enabled = false` (Gap 2)	Accept write, return `not_applicable`	Phase 3
D10	User-invite delivery mechanism (Gap 5)	Create as `invited`; email via NotificationsModule	M2.10
D11	WCAG-derived colour palette vs institutional branding (NS-02)	Proceed with palette; swappable via one Tailwind config	M2.6
D12	Recruiter Kanban/Analytics read-only below 768 px (Phase 1 §7.13)	Approve	M2.8

M2.1: authorised and in progress. **M2.2:** unblocked — D1 and D2 resolved. Remaining open items D3–D12 do not gate the schema.

Status: M2.1 (workspace scaffold) authorised. No database schema, no business logic, no model training.

Phase 1 → Phase 2 Handoff Specification v1.1 · Riya Jaiswal · GD Goenka University · B.Tech CSE · 2026–27
Traceable to Master PRD v3.0 and Phase 1 Requirements & UX Design v1.0